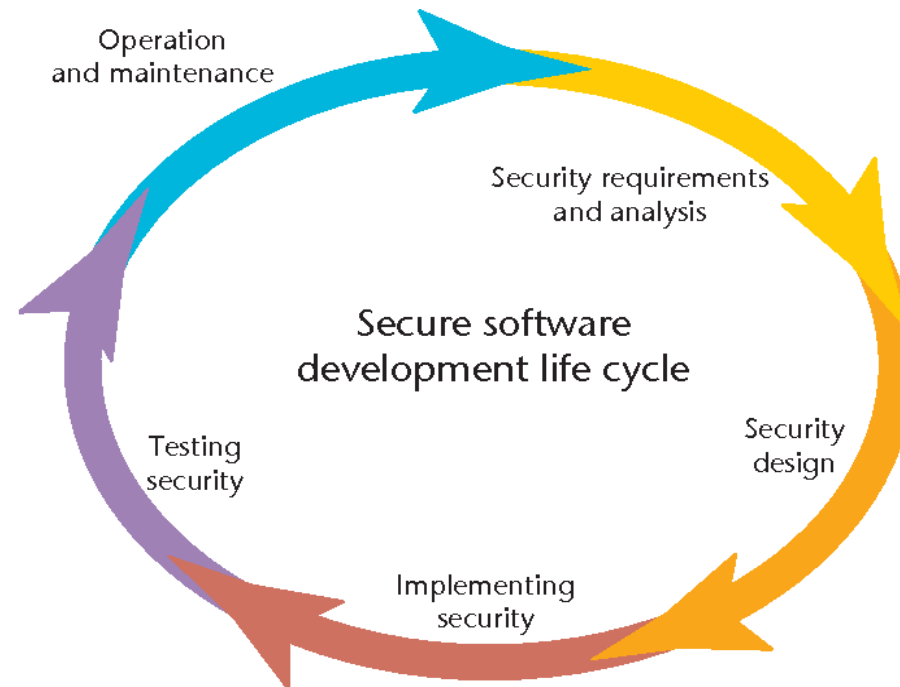


ICT2216



Secure Software Development

Our team

- First half:
 - Tram Truong Huu
- Second half:
 - Raymond Chan
- Labs:
 - Raymond Chan,
 - Tram Truong Huu
 - Marcus Tan



General information

- **Lectures:**
 - Every Thursday, 9 am – 11 am
 - Classroom: Zoom
- **Labs: Every Thursday**
 - P1: 1 pm – 3 pm
 - P2: 3 pm – 5 pm
 - Lab room: E2-07-14



To begin...

Before we go into the boring details, why we need to study secure software development?

Let's take a look how those BIG companies are doing!

Anthropic's AI Coding Tools

Anthropic's AI Coding Tool Leaks Its Own Source Code For The Second Time In A Year

A researcher flagged the issue on 31 March 2026, and the code has since been archived on multiple public repositories, raising fresh questions about the company's software release practices.

Edited by: [Nikhil Pandey](#) | [Science](#) | Mar 31, 2026 17:33 pm IST ⓘ

Read Time: 4 mins

Trusted Source on 

 Share



Chaofan Shou  

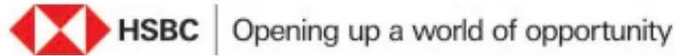
@Fried_rice

Claude code source code has been leaked via a map file in their npm registry!

Code: [...a8527898604c1bbb12468b1581d95e.r2.dev/src.zip](#)

This was a
packaging
mistake rather
than a hack!

HSBC India: The Uppercase Migration



Dear Customer,

We would like to inform you that your Internet Banking passwords will now become UPPER case-sensitive and the same will be in effect from 6 April 2026 onwards. When logging in, please enter your existing password using capital letters. For example, if your password is Test123, please enter TEST123 from 6 April 2026.

For any further assistance, please visit your nearest branch or call [HSBC PhoneBanking](#). HSBC Premier customers can also reach out to their Relationship Manager.

Please note: You can continue to log in using biometrics or secure token and there is no change to these options.

Yours sincerely
HSBC India

MM_INTERNET_BANKING_03/26



Beginning April 6, 2026, HSBC India will require its internet banking customers to enter their passwords in uppercase letters only.

Standard cybersecurity practices dictate that credentials must always be stored as one-way hashes, rendering the original input unreadable.

It should be literally impossible for a vendor to know your credentials' casing unless they weren't storing passwords as hashes. This anomaly has fueled industry speculation about **potential plaintext password storage or deeply flawed legacy security practices.**

By eliminating lowercase letters from the allowable character set, **the bank effectively cuts password options in half.**

[Products and Services](#)[Solutions](#)[Support](#)[Learn](#)[Why Cisco](#)[Support](#) / [Product Support](#) / [Security](#) / [Cisco Identity Services Engine](#) /

Security Advisories, Responses and Notices

[Cisco Identity Services Engine Stored Cross-Site Scripting Vulnerability](#) 15/Jan/2026

[Cisco Identity Services Engine Cross-Site Scripting Vulnerability](#) 15/Jan/2026

[Cisco Identity Services Engine XML External Entity Processing Information Disclosure Vulnerability](#) 07/Jan/2026

[Cisco Identity Services Engine Reflected Cross-Site Scripting and Information Disclosure Vulnerabilities](#) 04/Dec/2025

[Cisco Identity Services Engine RADIUS Suppression Denial of Service Vulnerability](#) 05/Nov/2025

[Cisco Identity Services Engine Arbitrary File Upload Vulnerability](#) 20/Aug/2025

[Cisco Identity Services Engine Stored Cross-Site Scripting Vulnerabilities](#) 06/Aug/2025

[Cisco Identity Services Engine Unauthenticated Remote Code Execution Vulnerabilities](#) 24/Jul/2025

Am I a victim?

';--have i been pwned?

Check if your email address is in a data breach

Using Have I Been Pwned is subject to the [terms of use](#)

 Generate secure, unique passwords for every account

[Learn more at 1Password.com](#)

Why 1Password?

879
pwned websites

14,949,479,875
pwned accounts

115,799
pastes

229,165,825
paste accounts

Largest breaches



772,904,991 [Collection #1 accounts](#)



763,117,241 [Verifications.io accounts](#)



711,477,622 [Onliner Spambot accounts](#)

Recently added breaches



162,373 [German Doner Kebab accounts](#)



16,627 [Troy Hunt's Mailchimp List accounts](#)

Question time

For SE student:

- In your previous modules, did you consider security when you were doing your project?

For IS student:

- In your previous modules, did you learn how to validate whether an application is secure or not?

Civil War?

IS Student:

- ICT2212 Ethical Hacking
- ICT2213 Applied Cryptography
- ICT2214 Web Security
- ICT2215 Mobile Security
- ICT2217 Network Security

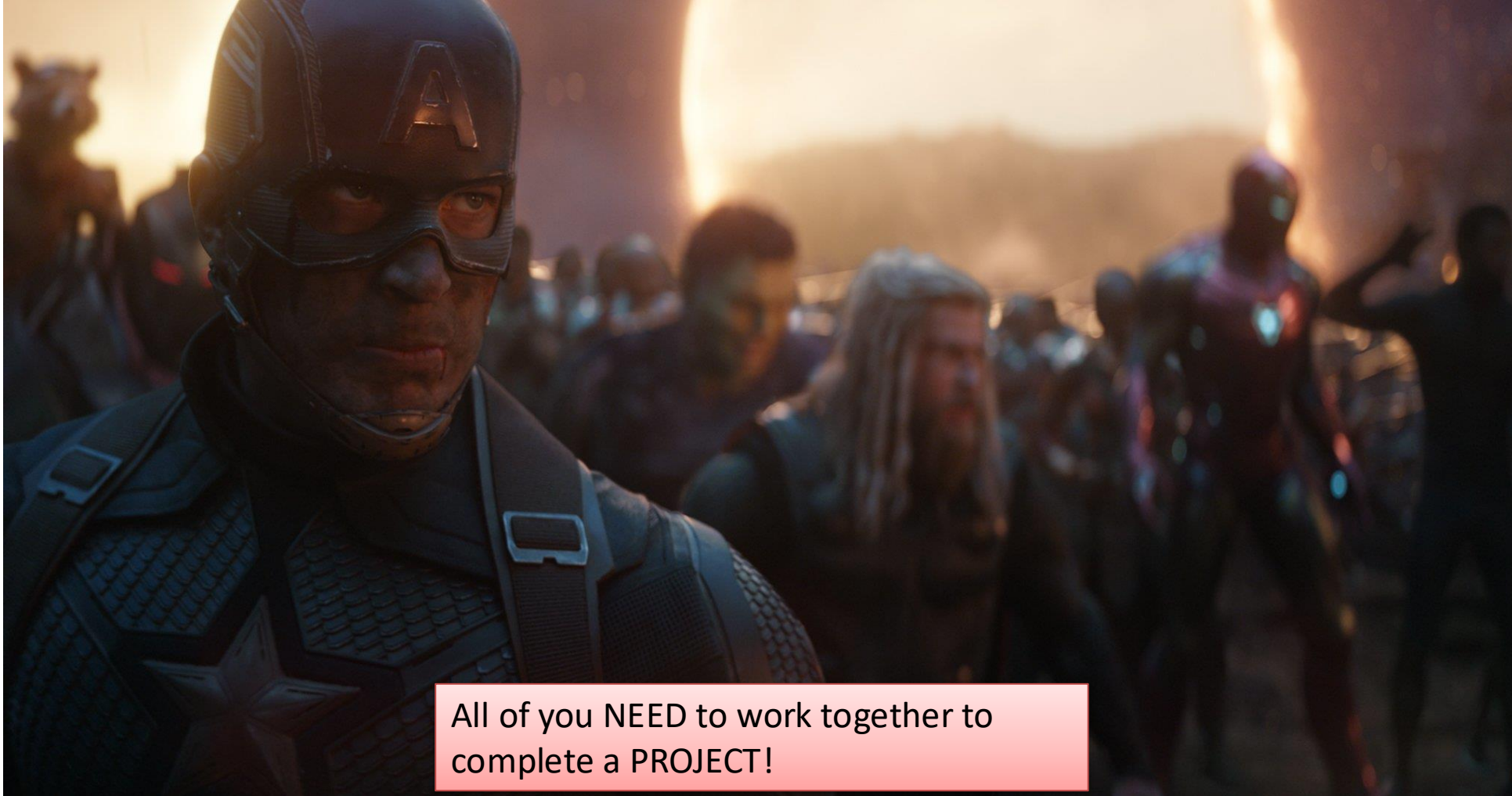


This module is to fight with each other?

SE Student:

- INF2001 Introduction to Software Engineering
- INF2002 Human Computer Interaction
- ICT2004 Embedded Systems Programming
- ICT2007 Mobile Application Development
- ICT2112 Software Design
- ICT2113 Software Modelling and Analysis

Assemble!



All of you NEED to work together to
complete a PROJECT!

So...Why you need to take this module?

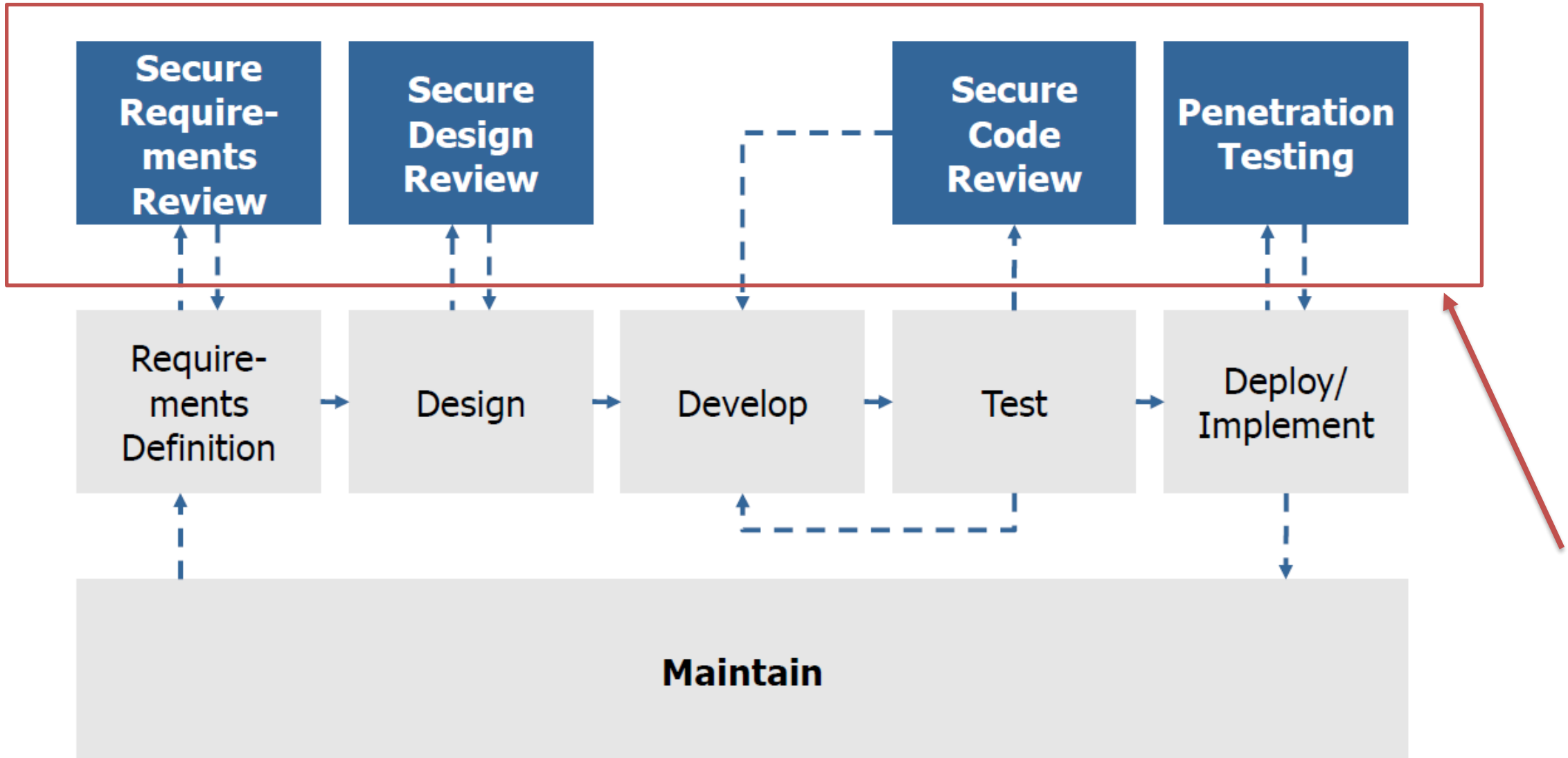
- Learn from the mistake!
- Security mindset when designing your application.
- Learn and apply the essential engineering principles and processes to the development of secure software.
- Learn the **security development life cycles**, (so call) best practices, secure coding and maintain software quality.

Module outline

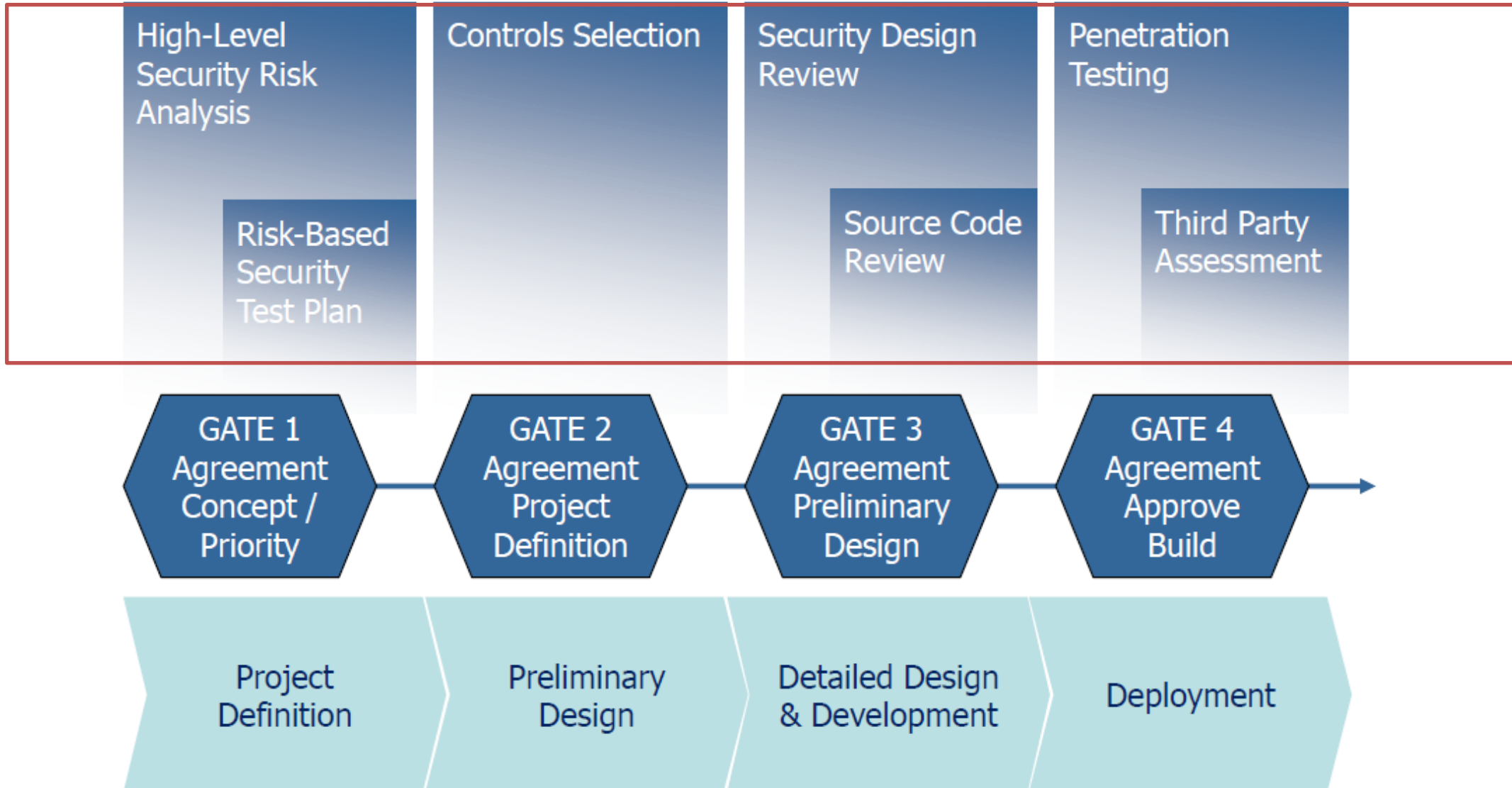
In the whole software development life cycle, we add “Secure” in front of them:

- **Secure** Software Concepts
- **Secure** Software Requirements
 - Risk Evaluation Guideline, and Requirements Criteria Doc.
- **Secure** Software Design
 - Security Design Review Guideline and Threat Modeling Guideline
- **Secure** Software Implementation/Coding
 - Security Coding Guide
- **Secure** Software Testing
 - Actives level, Security Testing Guideline
- **Secure** Software Deployment
 - Vulnerability Management and Incident Response Guideline

Secure software development life cycle



Security quality gates

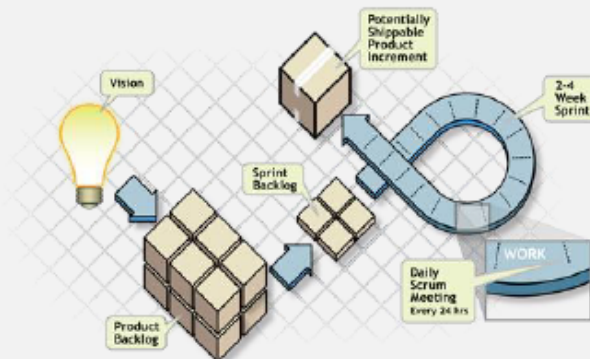


Sprint + Security

Security Sprint Approach

Security Sprint Approach:

- Dedicated sprint focusing on application security.
 - Stories implemented are security related.
 - Code is reviewed.
 - Stories may include:
 - ▶ Input validation story,
 - ▶ Logging story,
 - ▶ Authentication story,
 - ▶ Authorisation
- and some technical risks such as XSS, SQLI etc.



Every Sprint Approach

Every Sprint Approach:

- Similar to Microsoft Security Development Lifecycle (SDL).
- Consists of the requirements and stories essential to security.
- No software should ever be released without requirements being met.
- Sprint is two weeks or two months long.
- Every security requirement in the every-Sprint category must be completed in each and every Sprint.
 - ▶ Or the Sprint is deemed incomplete, and the software cannot be released.

Learning Outcomes

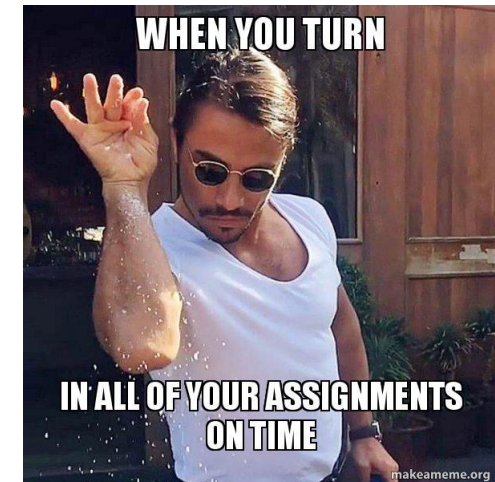
1. Recognize the **need for security practices** in different phases of a software development lifecycle
2. Model **secure software requirements** and threats with suitable UML diagrams
3. Apply appropriate **security principles** to secure software design
4. Implement **secure software coding** with reference to the recommended best practices
5. Perform **secure software verification** using suitable tools and techniques

Schedule (TBC)

S/No	Topics	Lectures (hours)	Labs (hours)
1	<u>Secure Software Concepts</u>	2	2
2	<u>Secure Software Requirements</u>	2	2
3	<u>Secure Software Design</u>	5	5
4	<u>Secure Software Implementation/Coding</u>	8	8
5	<u>Secure Software Testing</u>	4	4
6	<u>Secure Software Deployment</u>	3	3
	Total (hours)	24	24

Assessment

Assessment Task	Weightage
One page project proposal	5%
Project Deliverable 1: Secure Software Requirements & Design	20%
Project Deliverable 2: Secure Software Implementation	25%
Project Deliverable 3: Secure Software Verification	20%
Quizzes and Practical Test (Individual)	30%



Individual Assessment

- 1 quiz (Week 6 – 11 June 2026)
- 1 practical test (Week 12 – 23 July 2026)

Advices

- Do not hesitate to **ask** questions, offer your **point of view**, share your **experiences**.
 - Other people in the audience may have similar questions too.
- Do not hesitate to report potential **bugs or errors**
- Do not hesitate to look for **solutions** on the Internet
- NO **perfect** solution, once you need to develop an application.
- Learn from **mistakes** and **dramas**!

Item	Deliverables	Due	Weightage
1	One page project proposal: - Team Members and Lab Group Number - Team Name - Project Title - Project Description - Programming languages and packages to be used - Declaration that your secure web app to be developed is not an adaption of existing codes Evaluation criteria: - Required information above - Creativity and Impact Note: Some of third-party libraries (e.g., OAuth) are NOT allowed to be used in the project. Please discuss with lab instructors on your libraries.	Week 2, Thursday 14 May 9:00 am	5%

- Physical lab this afternoon
- Announcing the project details
- Form your dream team
 - A size of 7 to a maximum of 8 members in the same lab group
 - Strictly follow the team formation shown in the table below.

Project groups	Information Security	Software Engineering
P1 – 18 groups 78 IS – 54 SE	12 groups of 4 students 06 groups of 5 students	18 groups of 3 students
P2 – 18 groups 76 IS – 55 SE	14 groups of 4 students 04 groups of 5 students	17 groups of 3 students 01 group of 4 students

Reference

Secure Programming with Python

<https://www.amazon.com/Secure-Programming-Python-Tamaghna-Basu/dp/1786466465>

Microsoft Security Development Lifecycle

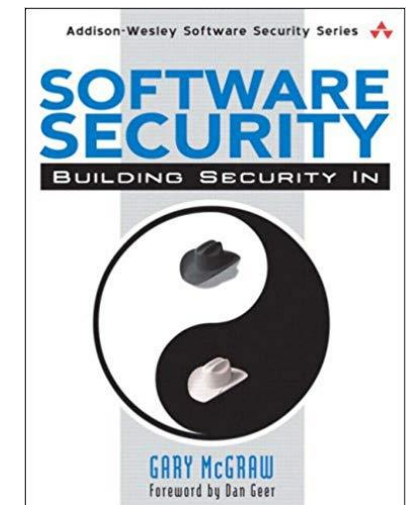
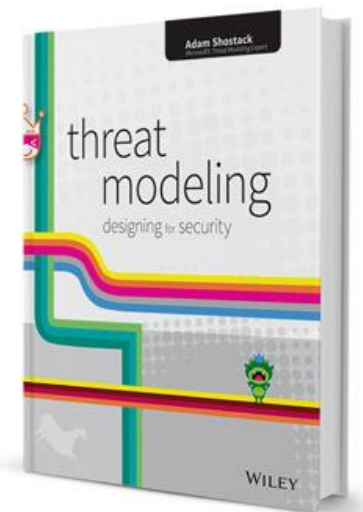
<https://www.microsoft.com/en-us/securityengineering/sdl>

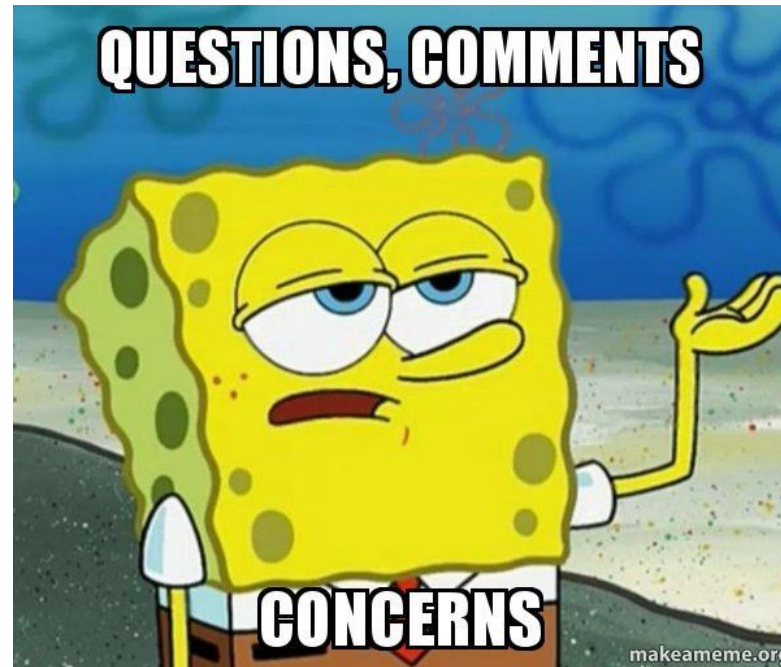
Software Security: Building Security In

<https://www.amazon.com/Software-Security-Building-Gary-McGraw/dp/0321356705>

Threat Modeling: Designing for Security

<https://www.amazon.com/Threat-Modeling-Designing-Adam-Shostack/dp/1118809998>





QUESTION OR COMMENTS?